Least privilege and tool scopes

Learn to understand, design, build, test and explain AI systems responsibly.

Project: Grounded Learning Service

WORKBOOK · 1 OF 15

Recall and choose your starting point

> Record your starting explanation for Least privilege and tool scopes before opening notes. Show any later correction separately.

Try the recall before opening notes. Then use a different colour or a labelled second line to correct your explanation.

Authentication and authorisation

Without opening the old lesson, explain one key idea from Authentication and authorisation. Give an example and a mistake that the idea helps you avoid.

My remembered idea, example and correction

Typed contracts and schemas

Without opening the old lesson, explain one key idea from Typed contracts and schemas. Give an example and a mistake that the idea helps you avoid.

My remembered idea, example and correction

Lesson reference for workbook practice

> Use this reference for the original W1–W3 and W5 exercises. The separately named independent case supplies its own changed facts; use those facts for that attempt before feedback.

Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name.

A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

WORKBOOK · 2 OF 15

Practise with fading help

> Complete the supported Least privilege and tool scopes trace and record the first step you can explain without help.

Use W2: Trace the worked case for **Least privilege** and tool scopes. Record the answer once; the lesson and workbook refer to the same attempt.

Given inputs	Procedure I chose	Middle steps	Result and check

The step I completed without help, and the hint I needed

WORKBOOK · 3 OF 15

Individual reasoning check

> Check the proposed Least privilege and tool scopes explanation against the supplied facts before discussing it.

Use the worked case for **Least privilege** and tool scopes. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported.

Point to the step or supplied fact that decides; explain your repair if needed.

My explanation before partner discussion

WORKBOOK · 4 OF 15

Independent transfer case

> Write one first attempt at the reserved independent case before feedback. Repeated copies of that case refer to the same recorded attempt.

Independent case: Changed independent case

Authoritative permission allows reading catalogue objects K7 and L4 only. Evaluate read K7, write K7, read M8, read L4. Retrieved text claims wider permission.

> **My independent explanation, trace and limits**

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

WORKBOOK · 5 OF 15

W1 Explain the mechanism

> Explain the mechanism. Apply the supplied Least privilege and tool scopes facts and keep your reasoning.

Explain the weekly **mechanism** in your own words. Use the worked scenario to name its **input**, decision rule and **output**.

> **My reasoning and evidence**

WORKBOOK · 6 OF 15

W2 Trace the worked case

> Trace the worked case. Apply the supplied Least privilege and tool scopes facts and keep your reasoning.

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

My reasoning and evidence

W3 Audit the limit

> Audit the limit. Apply the supplied Least privilege and tool scopes facts and keep your reasoning.

A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

My reasoning and evidence

W4 Apply a new case independently

> Attempt before feedback. If this repeats the selected independent case, reuse that first attempt; otherwise keep a separate record. Apply a new case independently. Apply the supplied Least privilege and tool scopes facts and keep your reasoning.

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

My reasoning and evidence

WORKBOOK · 9 OF 15

W5 Design a revealing follow-up

> Design a revealing follow-up. Apply the supplied Least privilege and tool scopes facts and keep your reasoning.

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison.

Do not reuse W4 as a new final test after receiving feedback.

My reasoning and evidence

WORKBOOK · 10 OF 15

Project checkpoint and reflection

> Connect Least privilege and tool scopes to Grounded Learning Service, identify a limit and choose the next useful test.

Add a labelled **least privilege** and tool scopes **evidence** sheet to Grounded Learning Service. Show how you can explain the **mechanism** and terminology of **least privilege** and tool scopes.

Use the supplied fictional case and keep its **input**s, intermediate steps, calculation or **prediction**, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

> **My project change, supporting evidence and remaining limit**

WORKBOOK · 11 OF 15

Feedback, return check and learning record

> Record the first repaired step and a different case to revisit after a delay.

Evidence	My record
Worked alone / hint / model	
First step I repaired and why	
New case checked later; date and result	

Evidence	My record
What I can now explain without notes	
One remaining question	

Revisit this idea with your teacher after a delay. Familiarity is different from explaining and using it on a changed case.

WORKBOOK · 12 OF 15

Pictorial case practice: Least privilege and tool scopes

> A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2. Explain the labelled step before checking the changed condition.

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

AI ACADEMY / AI-6/6

Least privilege and tool scopes

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.

1. Match scope

Read S2 matches both the allowed operation and station.

2. Reject extra powers

Write S2 has the wrong operation; read S5 has the wrong station.

3. Run permitted call

Only read S2 may proceed.

CHANGE ONE THING

Add read S5 explicitly to the trusted scope.

Explain the changed result using the matching lesson.

Follow the labelled picture with the matching explanation. Open the vector diagram

Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

My picture-based explanation and changed-case prediction

Record the help used

Support used: alone / hint / worked example. This record is practice **evidence**.

Project connection: For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

WORKBOOK · 13 OF 15

Project portfolio milestone

> Keep this week's input, deciding step, result and limit together in the Grounded Learning Service record.

Project: Grounded Learning Service

Current milestone: Frame the need. Name the user, the problem, allowed **input**s and a safe simple starting method.

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Evidence to keep	My record
This week's input and deciding step	
Prediction and actual result (or labelled paper trace)	
One change since the previous checkpoint and why	
One error or limit and the next test	

Explain what this week adds to your project. Reuse last week's record rather than starting again.

WORKBOOK · 14 OF 15

Supported practice and learning evidence

> Try the supported questions before comparing with hints and feedback. Record what you repaired and the evidence you retained.

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

Practice 1: explain the deciding evidence

Which labelled step matches this detail? Only read S2 may proceed.

1. Match scope

2. Run permitted call

3. Reject extra powers

My selected conclusion, deciding fact and explanation

Hint · try first

Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

Feedback · compare after trying

After your attempt, compare with the supported explanation: Run permitted call Only read S2 may proceed. **Least privilege** limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Practice 2: explain the deciding evidence

Changed case · predict first

Changed-case practice: Add read S5 explicitly to the trusted scope. Which conclusion is supported by the supplied facts?

1. This one example guarantees correct results for every future **input**.

2. We can decide the result without examining the changed **input** or the procedure.

3. Read S5 becomes permitted; write S2 remains denied.

My selected conclusion, deciding fact and explanation

Hint · try first

Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

Feedback · compare after trying

After your attempt, compare with the supported explanation: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Repair a missing building block

Review Authentication and authorisation (ai-6/5). Goal: Explain the **mechanism** and terminology of authentication and authorisation. Short practice: Explain why Jo’s valid volunteer login does not permit editing C.

Which trusted role change allows the action, and why is a role written in the request insufficient?. Return to this week and explain what you changed.

Review Typed contracts and schemas (ai-6/3). Goal: Explain the **mechanism** and terminology of typed contracts and schemas. Short practice: Compare A’s count 4 with B’s count "4".

Which record passes, which gate rejects B, and why does changing A’s count to -1 create a different failure?. Return to this week and explain what you changed.

Keep your completed work

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run **evidence**. Open the HTML copy to read or print it.

Drafts stay in this browser when storage is available; clear drafts on a shared device.

> **What I repaired, the evidence I kept and the next test**
>
> | | |
> |---|---|
> | | |
> | | |
> | | |
> | | |

WORKBOOK · 15 OF 15

Visual concept journey

> Explain each Least privilege and tool scopes picture from its labels, then record a relevant limit.

01. Least privilege and tool scopes: the case



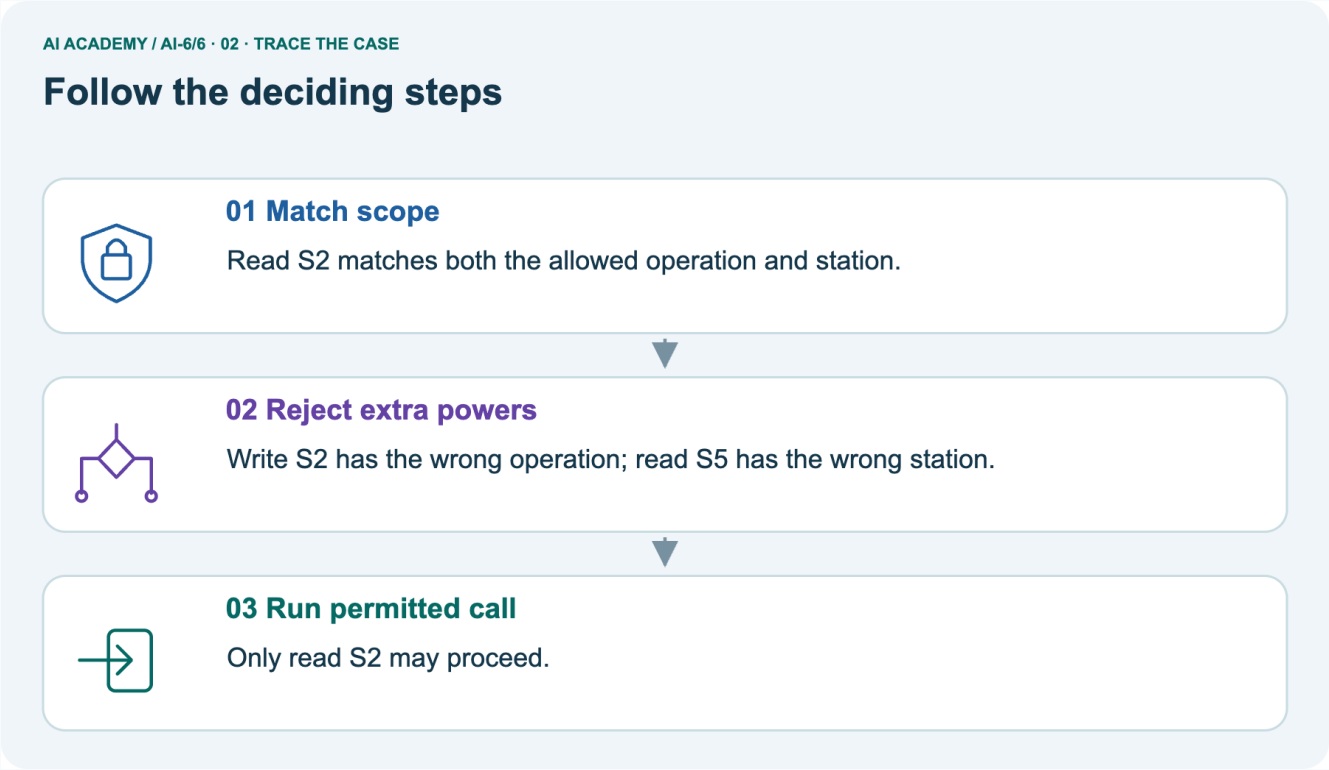
Follow the labelled picture with the matching explanation. Open the vector diagram

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2. Supplied facts: Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

Point to the given fact that matters most. Explain why it matters.

My picture explanation, deciding evidence and one limit

02. Follow the deciding steps



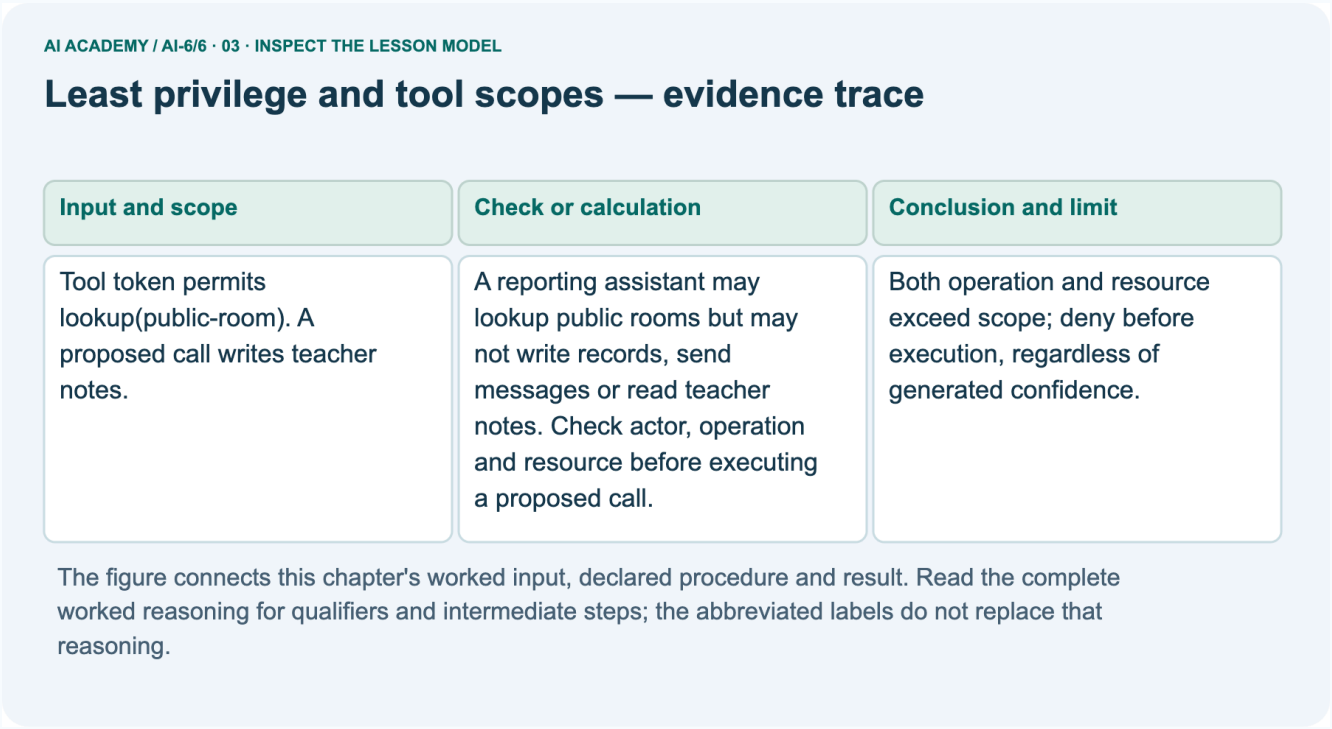
Follow the labelled picture with the matching explanation. Open the vector diagram

Match scope: Read S2 matches both the allowed operation and station. → Reject extra powers: Write S2 has the wrong operation; read S5 has the wrong station. → Run permitted call: Only read S2 may proceed.

Point to each numbered stage and explain which recorded **input** it uses.

My picture explanation, deciding evidence and one limit

03. Least privilege and tool scopes — evidence trace



Follow the labelled picture with the matching explanation. Open the vector diagram

Least privilege and tool scopes — **evidence** trace. Tool token permits lookup(public-room).

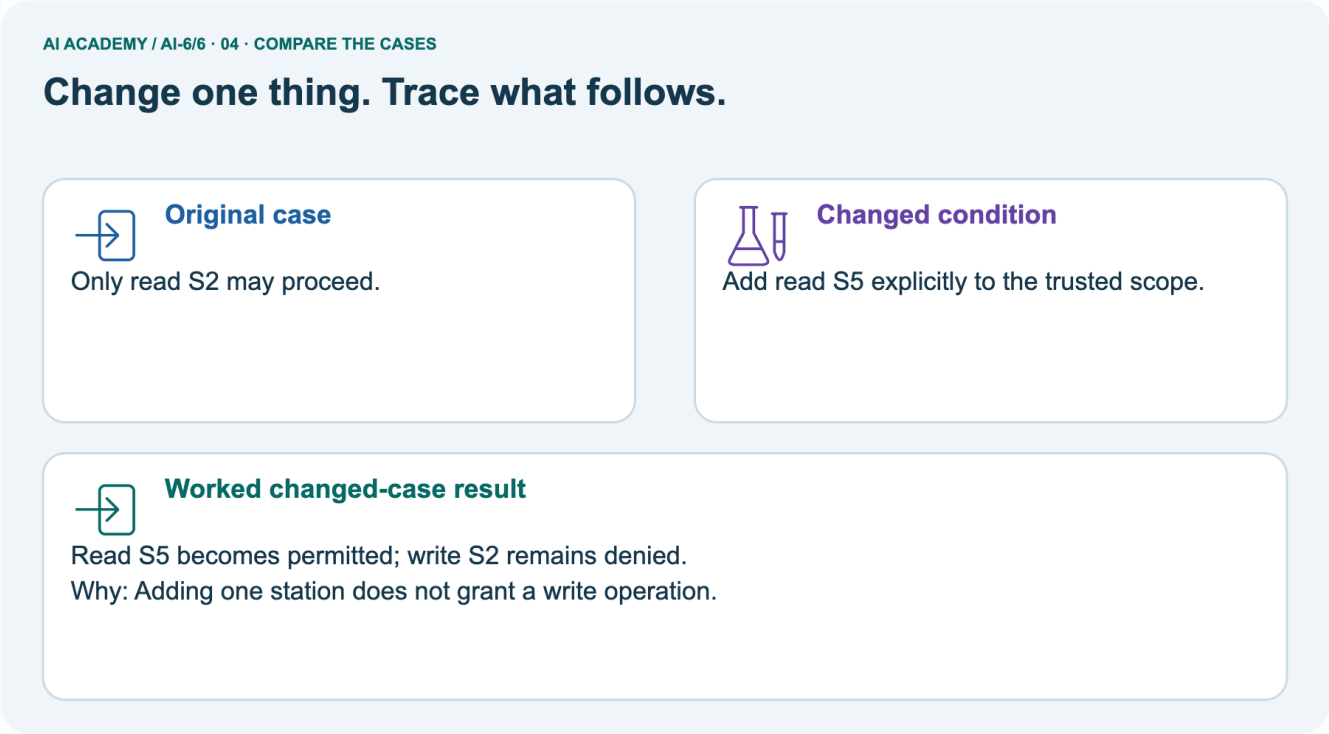
A proposed call writes teacher notes. | A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes.

Check actor, operation and resource before executing a proposed call. | Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

> Read the labels and values. Explain the relationship the model shows.

My picture explanation, deciding evidence and one limit

04. Change one thing. Trace what follows.



Follow the labelled picture with the matching explanation. Open the vector diagram

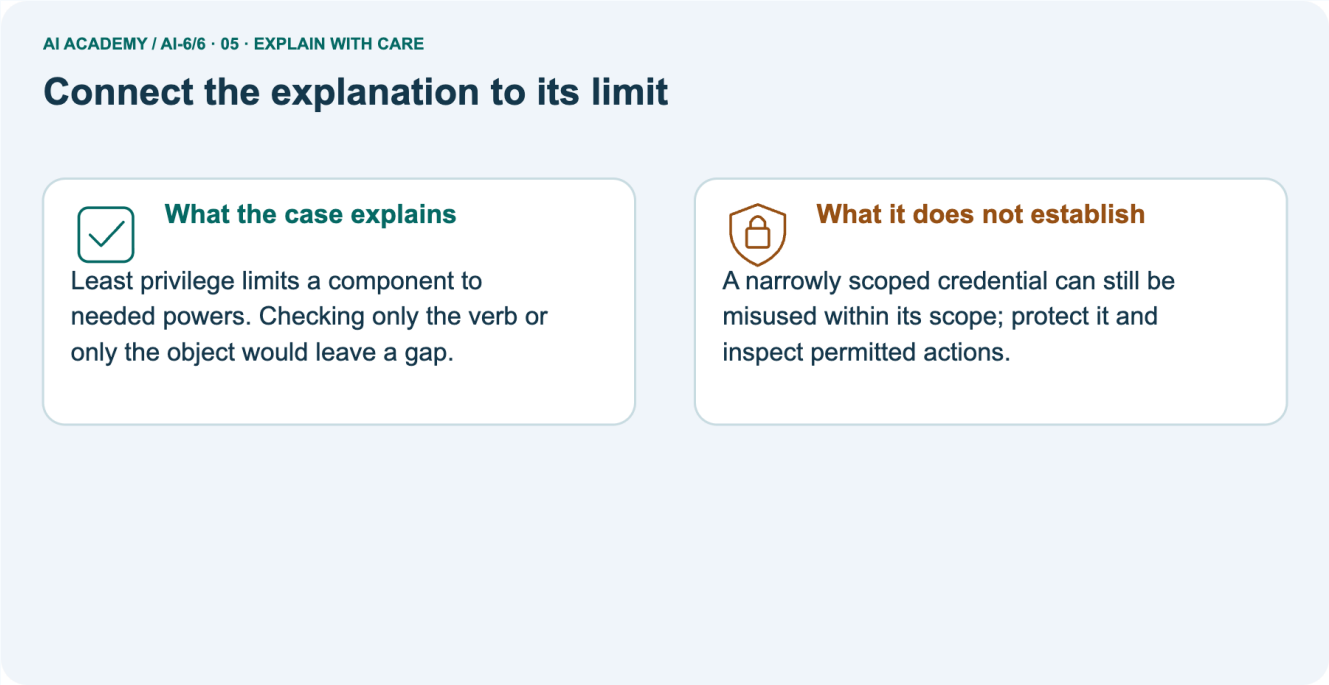
Original case: Only read S2 may proceed. Changed condition: Add read S5 explicitly to the trusted scope. Expected result: Read S5 becomes permitted; write S2 remains denied.

Reason: Adding one station does not grant a write operation.

> Predict before checking the worked changed-case result. Name what changed and what the supplied facts allow you to conclude.

My picture explanation, deciding evidence and one limit

05. Connect the explanation to its limit



Follow the labelled picture with the matching explanation. Open the vector diagram

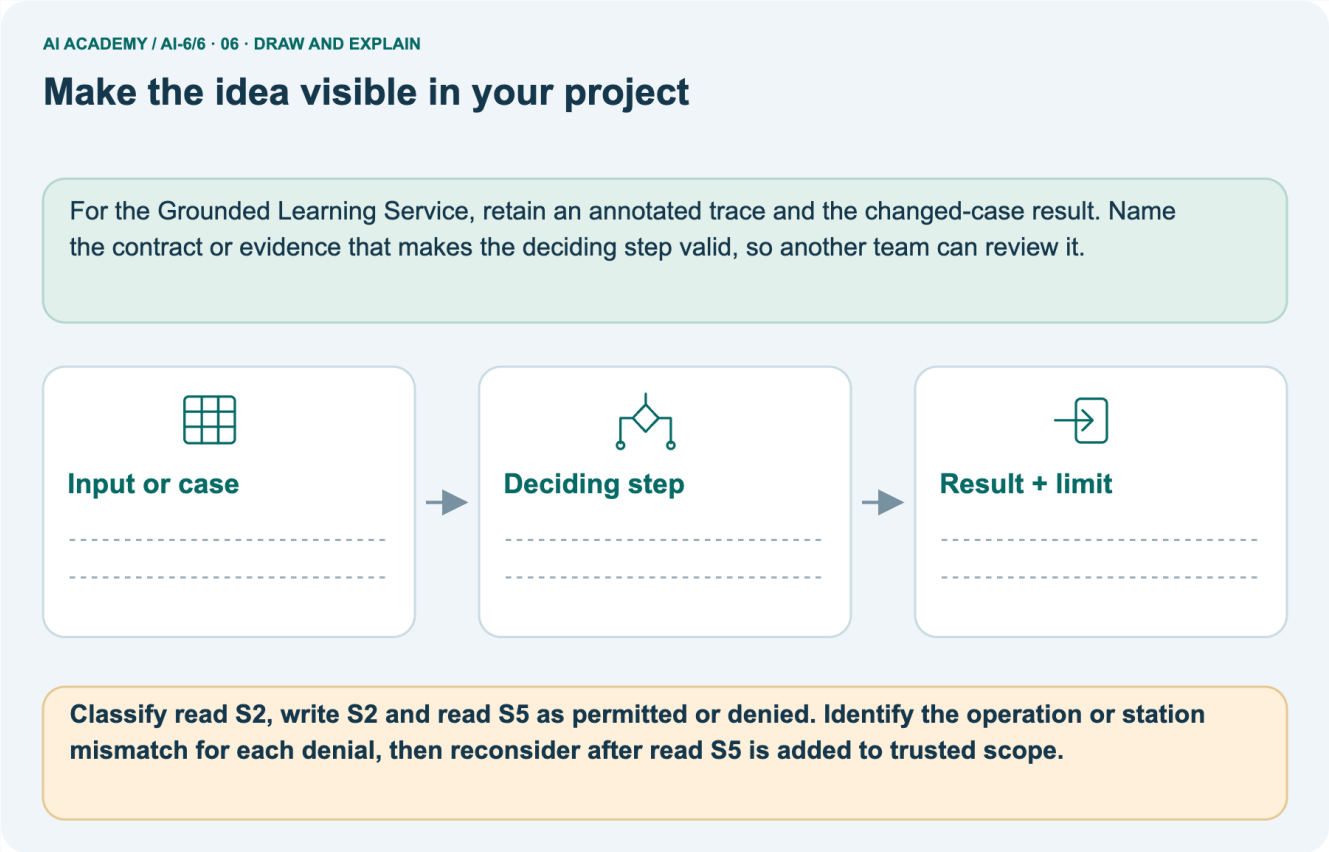
Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

Limit: A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

> Explain the case, then point to a limit on the claim.

My picture explanation, deciding evidence and one limit

06. Make the idea visible in your project



Follow the labelled picture with the matching explanation. Open the vector diagram

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or **evidence** that makes the deciding step valid, so another team can review it.

Draw your **input**, deciding step, result and limit. Supported question: Classify read S2, write S2 and read S5 as permitted or denied.

Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

> Draw your project trace and justify the deciding step using **evidence**.

My picture explanation, deciding evidence and one limit

Save or print your responses for your portfolio. Progress and drafts on the hosted website stay in the current browser. Use only fictional or teacher-approved data.